

Win-DoS EPIDEMIC

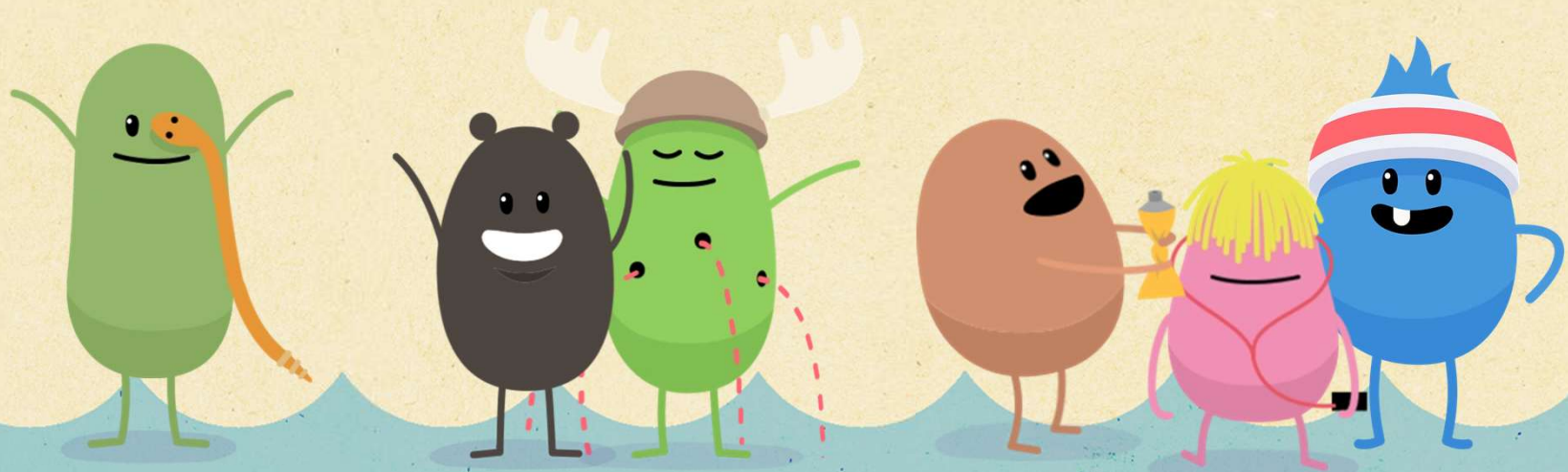
**A Crash Course in Abusing RPC
for Win-DoS & Win-DDoS**

Or Yair, Security Research Team Lead, SafeBreach

Shahak Morag, Research Lead, SafeBreach

Win-DoS EPIDEMIC

**A Crash Course in Abusing RPC
for Win-DoS & Win-DDoS**



OR YAIR



Security Research Team Lead at SafeBreach



7 years in Security Research



Past research in Linux, embedded, Android



4 years Windows research



SHAHAK MORAG



Research Lead at SafeBreach



7 years in Security Research



Past research in Linux kernel, embedded



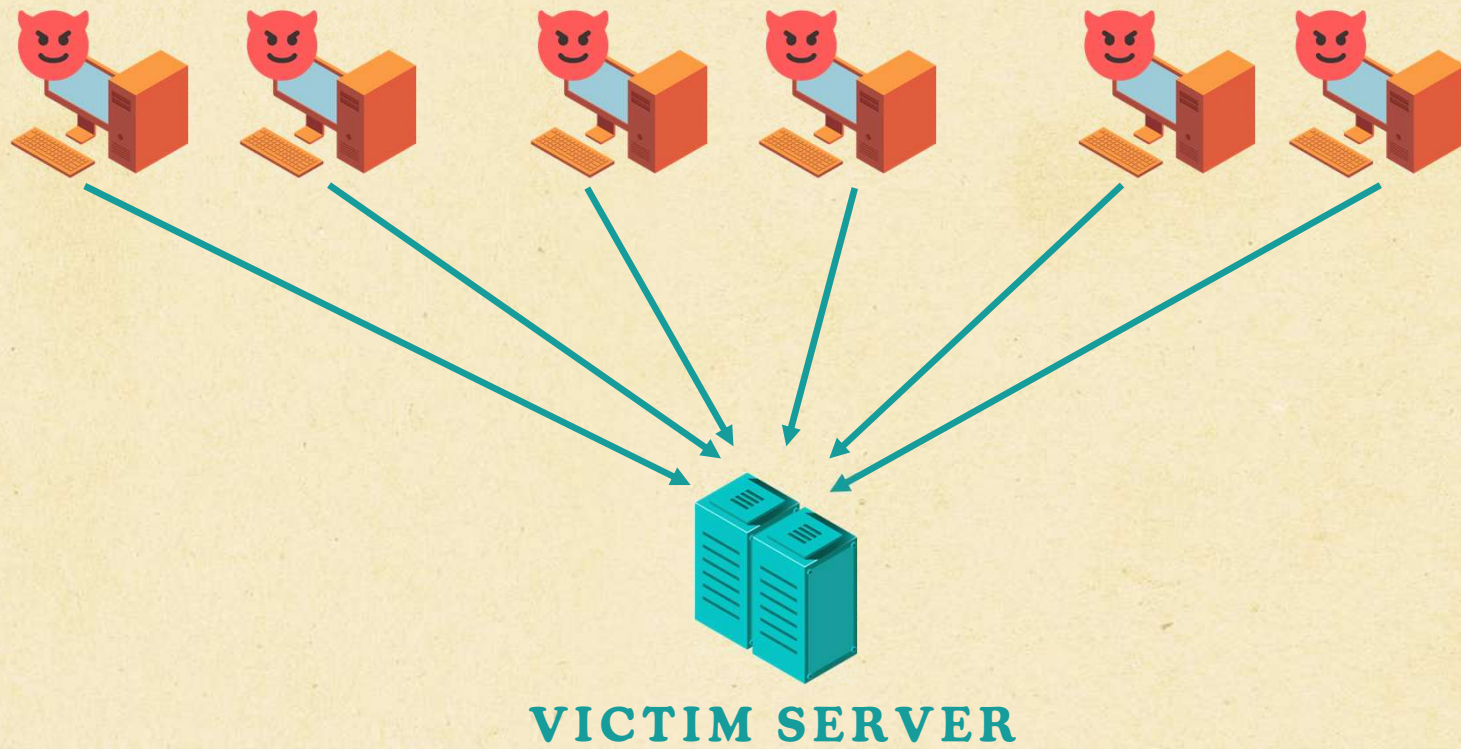
1+ years Windows research



AGENDA

1. DDoS & DoS
2. LDAPNightmare – Our gateway
3. Research Goals
4. Developers' Blind Spots
5. From DoS to DDoS
6. Vulnerability Discoveries
7. Takeaways
8. GitHub + Q&A

DDoS



Slide 6

SM1 רגיל DDOS אולי להוסיף בהתחלה הסבר על
Shahak Morag, 2025-07-03T09:47:09.768

OY2 Change to sketch
Or Yair, 2025-07-06T08:04:54.435

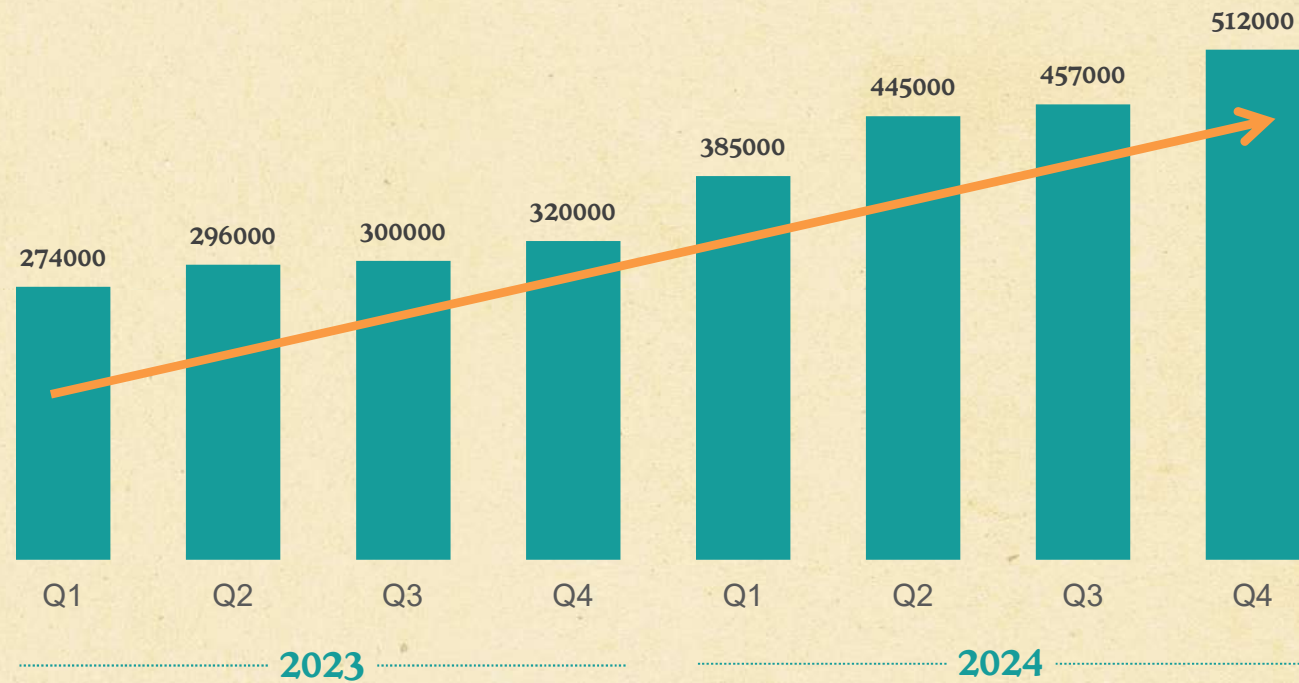
THE GROWING THREAT of DoS and DDoS ATTACKS



DDoS ATTACK INCREASE

Gcore Radar:

DDoS Attack Count 2023–2024





The Hacker News

652,146 followers

[Visit website](#)

1w •

+ Follow ...

SM1

A record-breaking DDoS attack just slammed a hosting provider with 7.3 Tbps of traffic.

It lasted 45 seconds—and bombarded 34,000+ ports per second.

Cloudflare blocked it. But RapperBot is just getting started.

Full story → <https://lnkd.in/gaNpA2B2>

Cloudflare defenses autonomously block a 7.3 Tbps DDoS attack



Slide 9

SM1

לשים זכוכית מגדלת

.פרטים על התקיפה, מי עשה אותה ומה הנזק

Shahak Morag, 2025-07-03T09:33:44.384

DoS HAS A PRICE



LDAPNightmare DoS

BY YUKI CHEN - OUR GATEWAY

 SafeBreach

[Why SafeBreach](#)

[Solutions](#)

[Use Cases](#)

[Resources](#)

[Our Partners](#)

[Company](#)

JAN 1, 2025

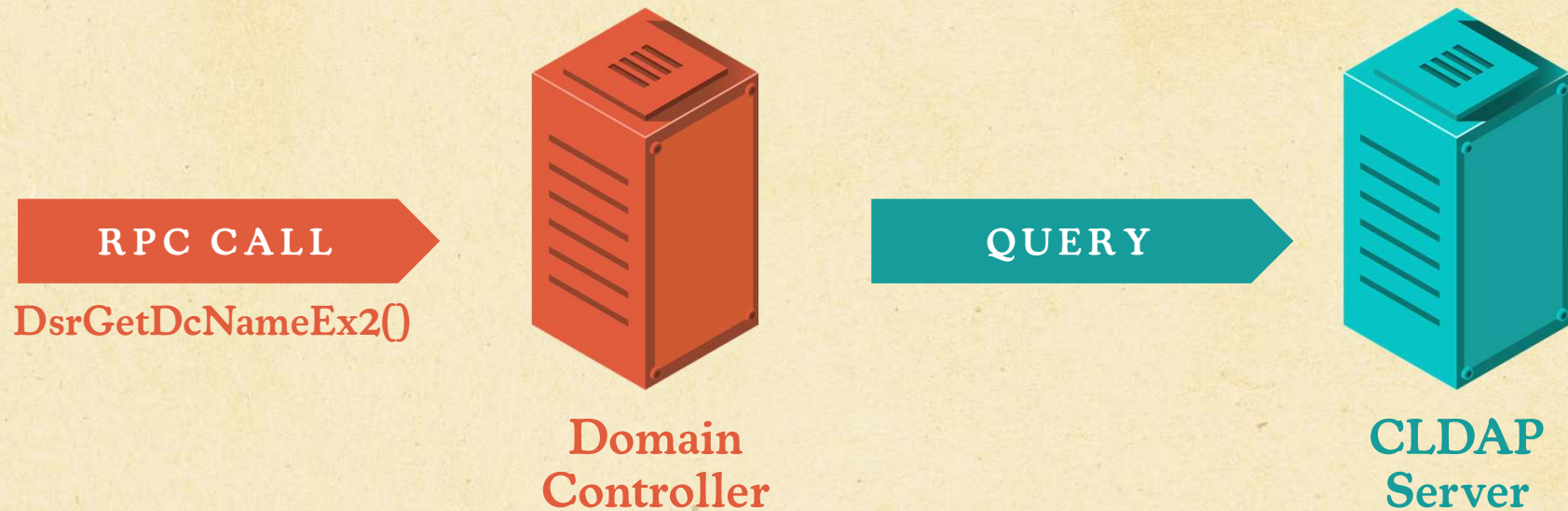
LDAPNightmare: SafeBreach Labs Publishes First Proof-of-Concept Exploit for CVE-2024-49113 DoS

See how SafeBreach Labs Researchers developed a zero-click PoC exploit that crashes unpatched Windows Servers using the Windows Lightweight Directory Access Protocol (LDAP) Denial of Service Vulnerability.

LDAPNightmare DoS

SERVICES TRANSFORMING INTO CLIENTS

CLDAP Client



LDAPNightmare DoS

SERVICES TRANSFORMING INTO CLIENTS



Domain
Controller

ANSWER WITH
INVALID VALUE



CLDAP
Server

LDAPNightmare **BLIND SPOT**

The LDAP client code
in Windows turned out
to be a blind spot!





RESEARCH GOALS

**DoS vulnerabilities in
developers' blind spots**

AIMING FOR DOMAIN CONTROLLERS



Domain Controllers are organizations' crown jewels

DEVELOPER BLIND SPOTS IN WINDOWS



DEVELOPER BLIND SPOTS IN WINDOWS

1. Remotely triggered client code –
Same as LDAPNightmare
2. Transport-agnostic wrapped server code

DEVELOPER BLIND SPOTS IN WINDOWS

1. Remotely triggered client code –
Same as LDAPNightmare
2. Transport-agnostic wrapped server code

RPC INTERFACES

[Learn](#) / [Windows](#) / [Apps](#) / [Win32](#) / [Desktop Technologies](#) / [Networking and Internet](#) /

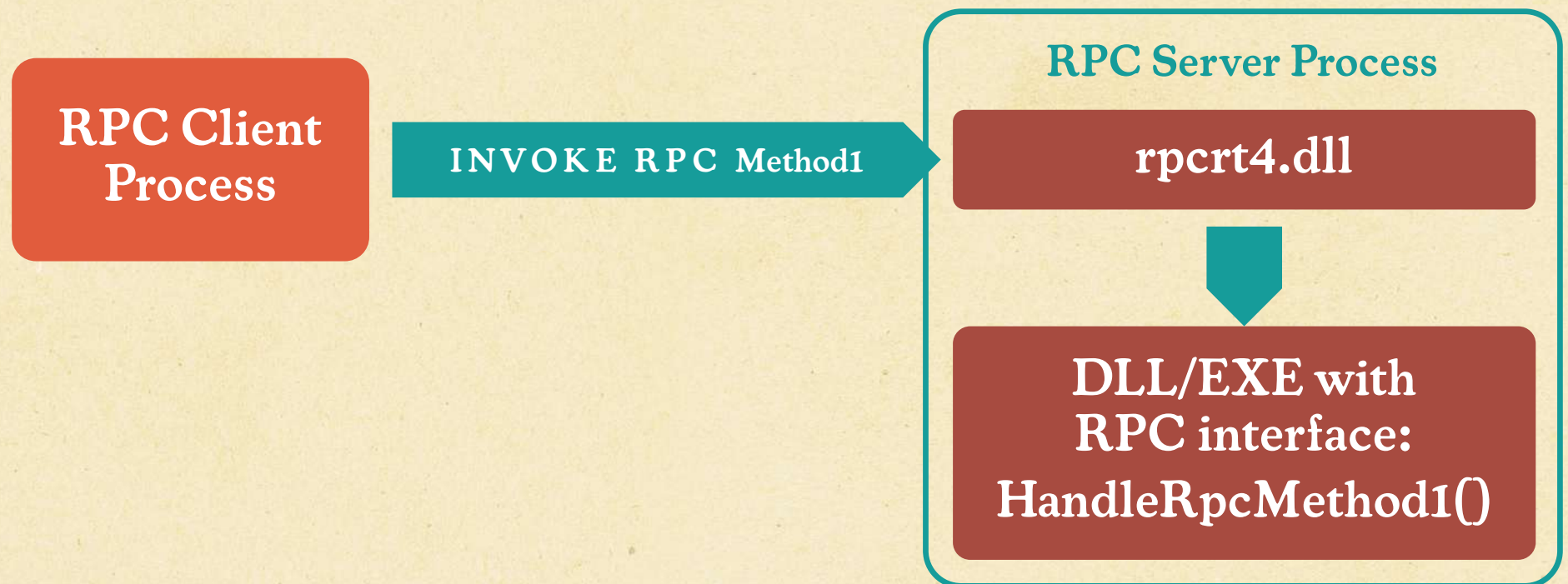
Remote procedure call (RPC)

02/08/2022

Microsoft Remote Procedure Call (RPC) defines a powerful technology for creating distributed client/server programs. The RPC run-time stubs and libraries manage most of the processes relating to network protocols and communication. This enables you to focus on the details of the application rather than the details of the network.



RPC INTERFACES ARE WRAPPED SERVERS!



RESEARCH ASSUMPTION

Developers are likely to forget about mitigating classic server risks in RPC servers



RESEARCH PROCESS



CLIENT CODE - LDAPNightmare

Domain Controllers can be turned into clients
effortlessly and anonymously

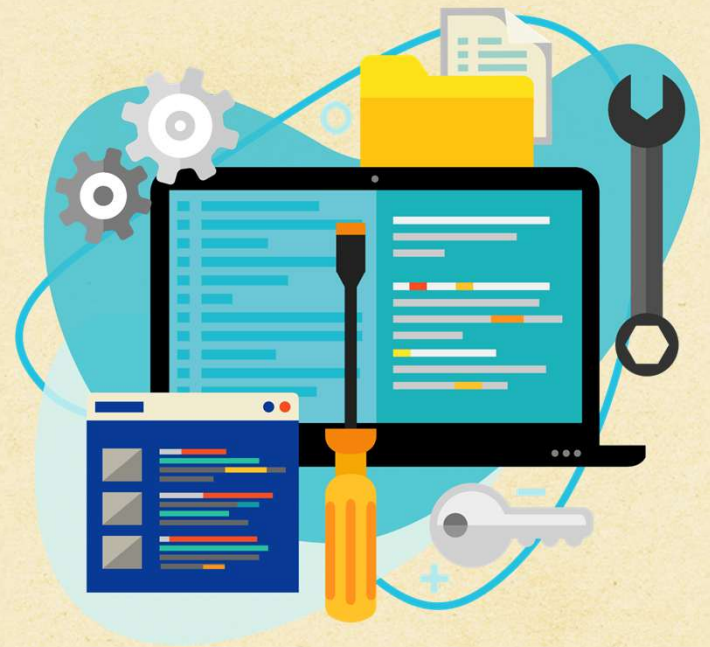
They trust any LDAP server

WINDOWS LDAP CLIENT CODE

Wldap32.dll

Support LDAP & CLDAP

Can be triggered using
NetLogon's RPC



LdapNightmare - LDAP Referrals

LDAPNightmare Root Cause:

OY1

- Bug in wldap32.dll's handling of LDAP Referral packets



Domain
Controller

LDAP REFERRAL WITH
INVALID VALUE

CLDAP
Server

Slide 26

OY1

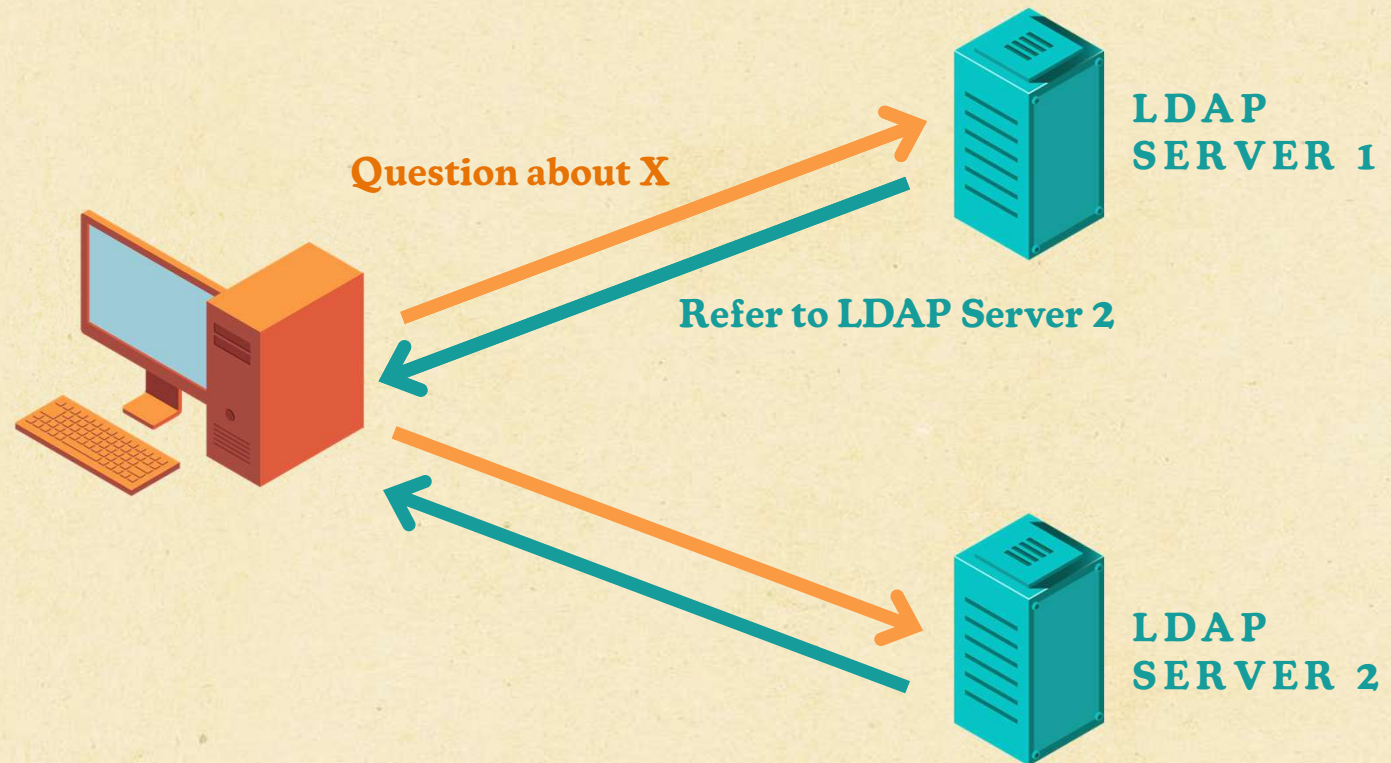
Add a textual list of LDAP referrals and talk about it in the notes

Or Yair, 2025-07-06T08:30:56.486

LdapNightmare - LDAP Referrals

Referrals:

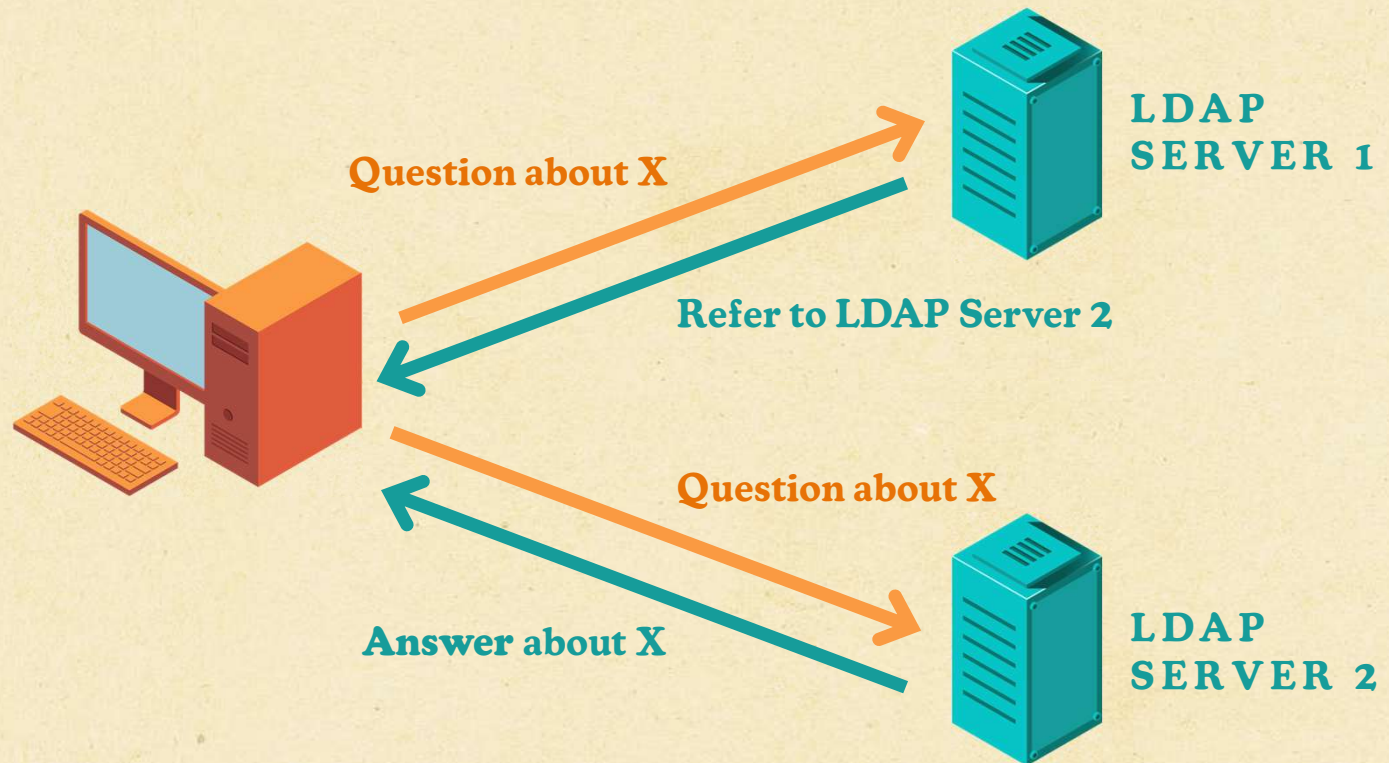
[
“ldap://server2.com”,
“ldap://server3.com”
]



LdapNightmare - LDAP Referrals

Referrals:

```
[  
  "ldap://server2.com",  
  "ldap://server3.com"  
]
```



**IF WE CONTROL THE
DIRECTION, CAN THAT PROVIDE
US DIFFERENT ABILITIES
BESIDES CRASHING?**

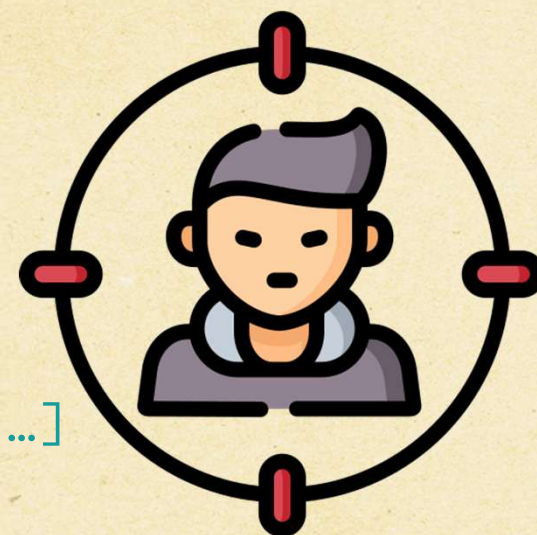
From DoS to DDoS

DDoS

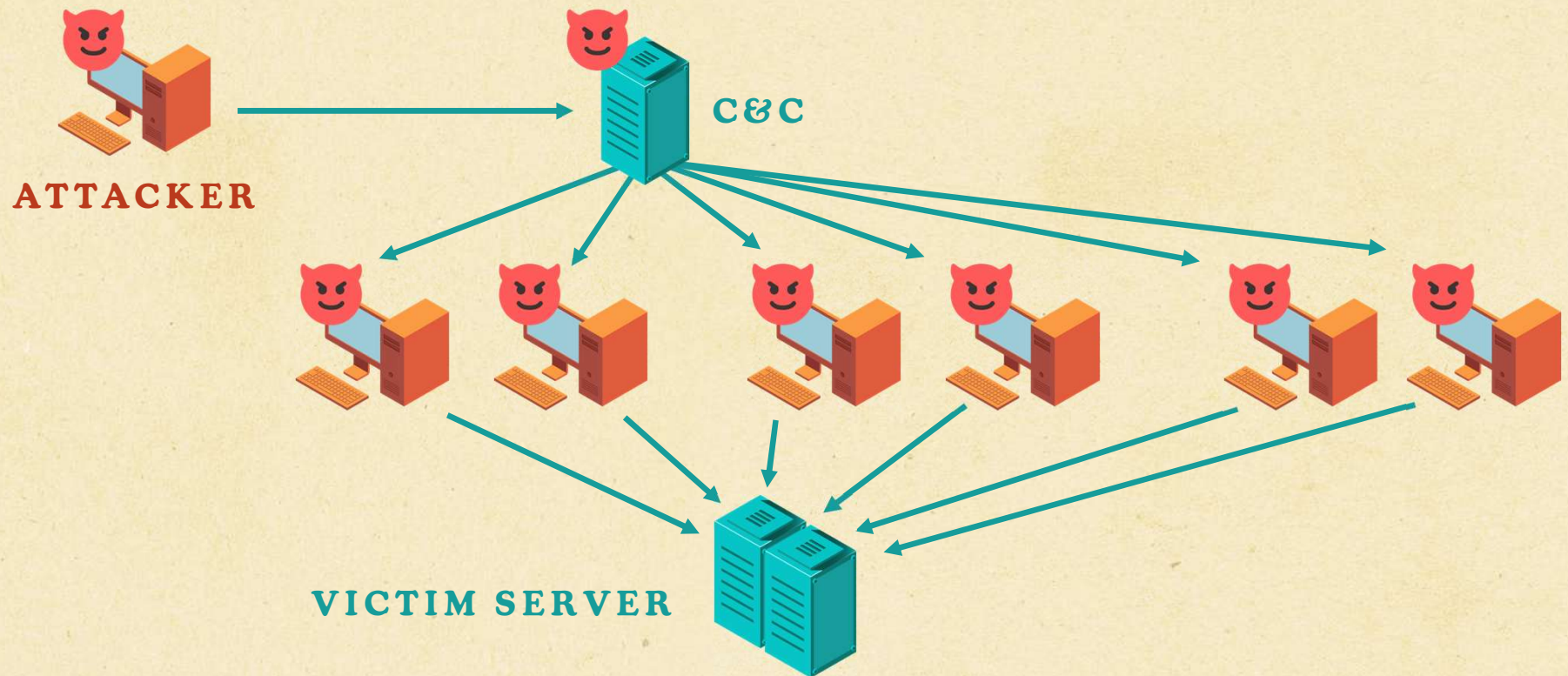
From DoS to DDoS - Harnessing LDAP Referrals

REFER x1000 TIMES TO THE VICTIM

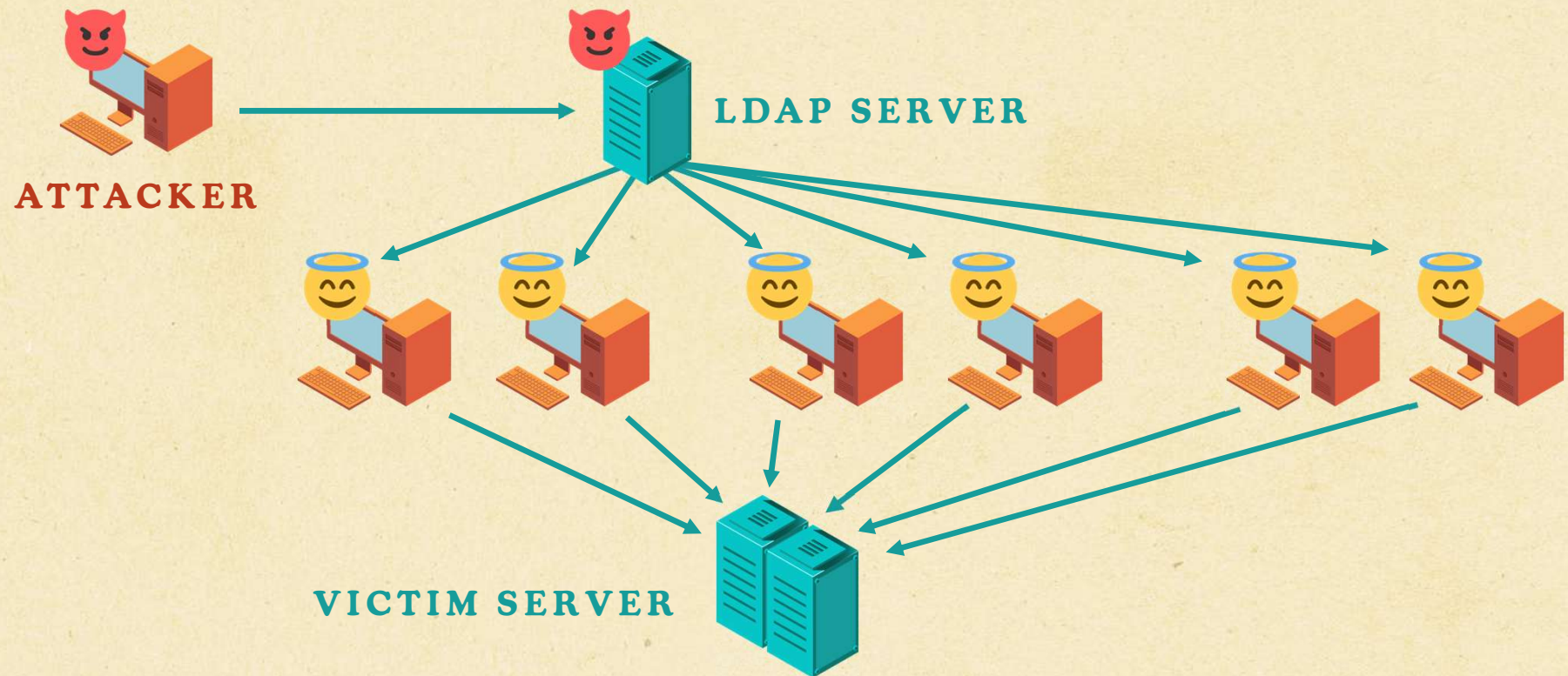
[“ldap://victim1.com:80”, “ldap://victim1.com:80”, ...]



From DoS to DDoS – DDoS flow



From DoS to DDoS – Potential Referral DDoS



TCP vs UDP

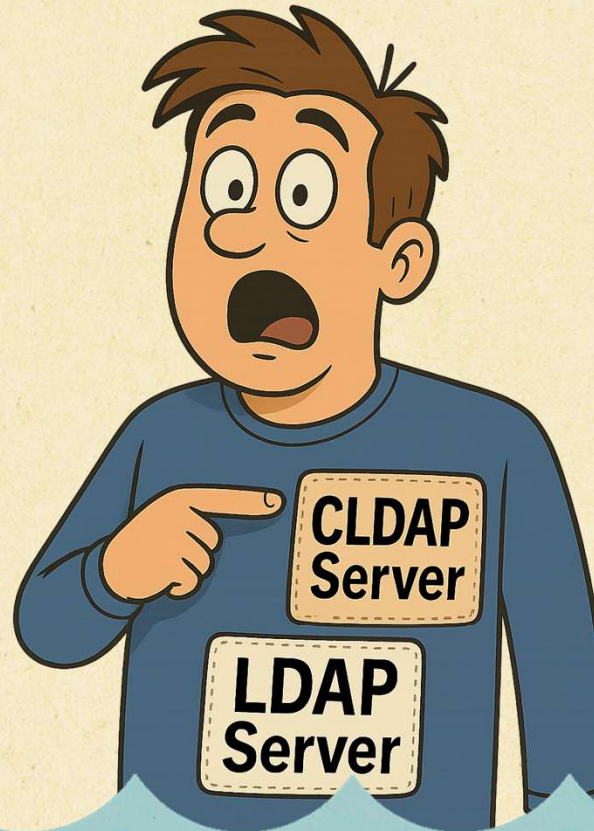


CLDAP - UDP



LDAP - TCP

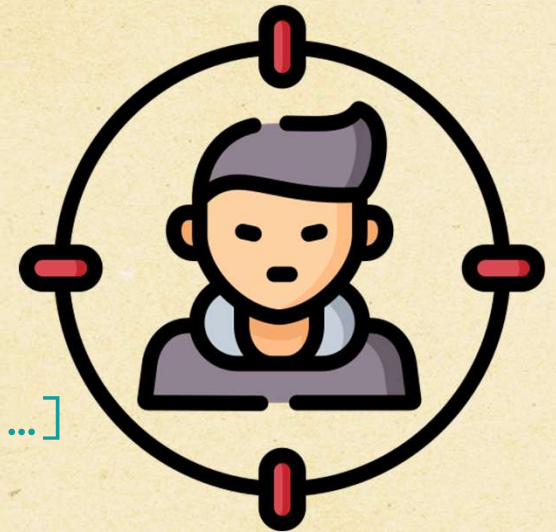
**REFER FROM OUR SERVER
TO OUR SERVER**



From DoS to DDoS - Harnessing LDAP Referrals

REFER x1000 TIMES TO THE VICTIM

[“ldap://victim1.com:80”, “ldap://victim1.com:80”, ...]



From DoS to DDoS challenge – Not so easy

`CheckForExistingReferral()` – Checks for duplicate referrals



DIFFERENT DOMAIN $\neq$ DIFFERENT IP

DNS Record: *.attacker-domain.com == 123.123.123.123

Referrals: [
 "ldap://a.attacker-domain.com:80",
 "ldap://b.attacker-domain.com:80",
 ...
]

Win-DDoS



Win-DDoS

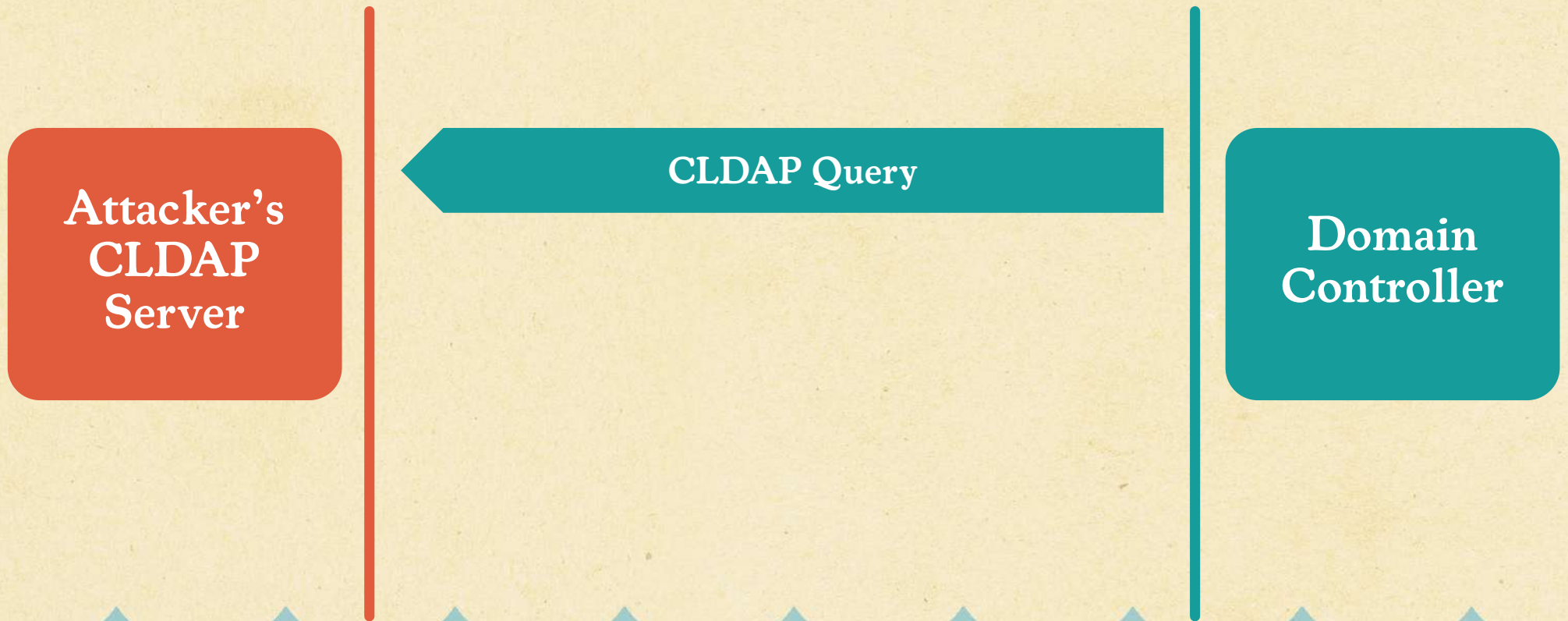
Attacker

DsrGetDcNameEx2()

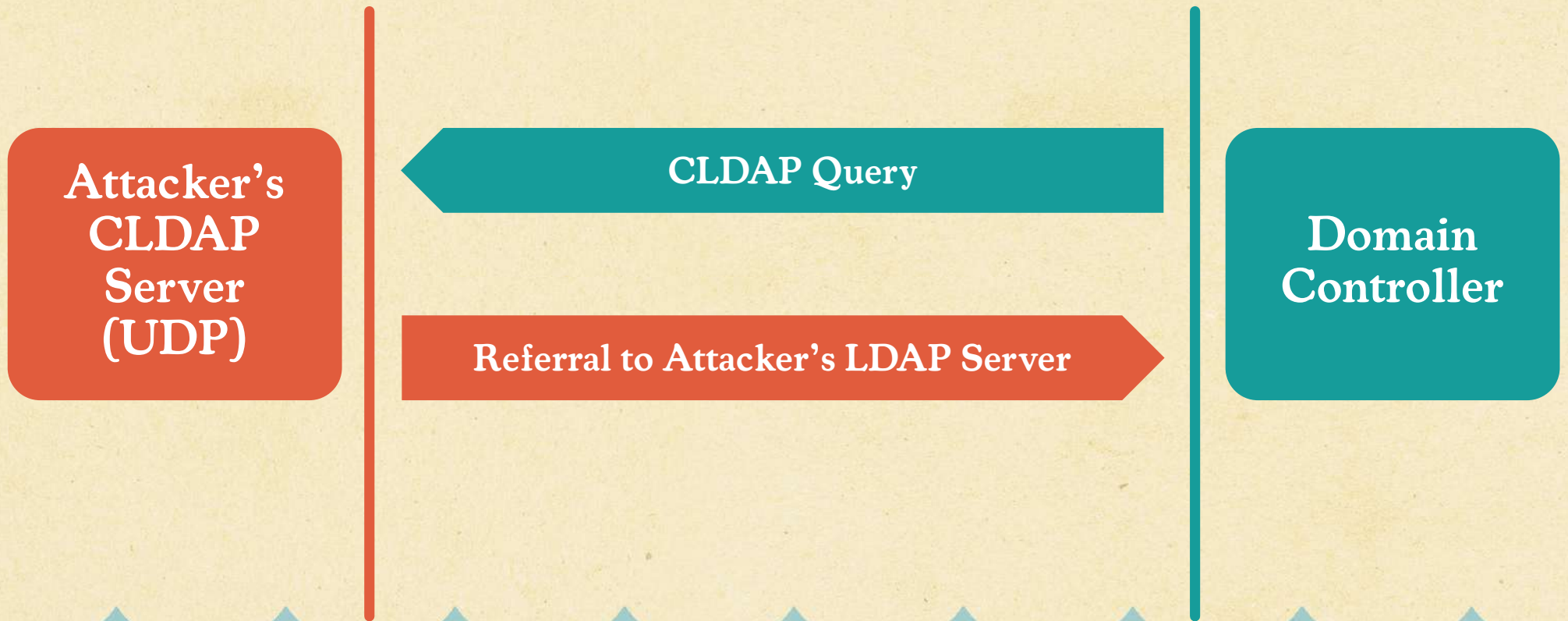
Forces the DC to become the
attacker's CLDAP client

Domain
Controller

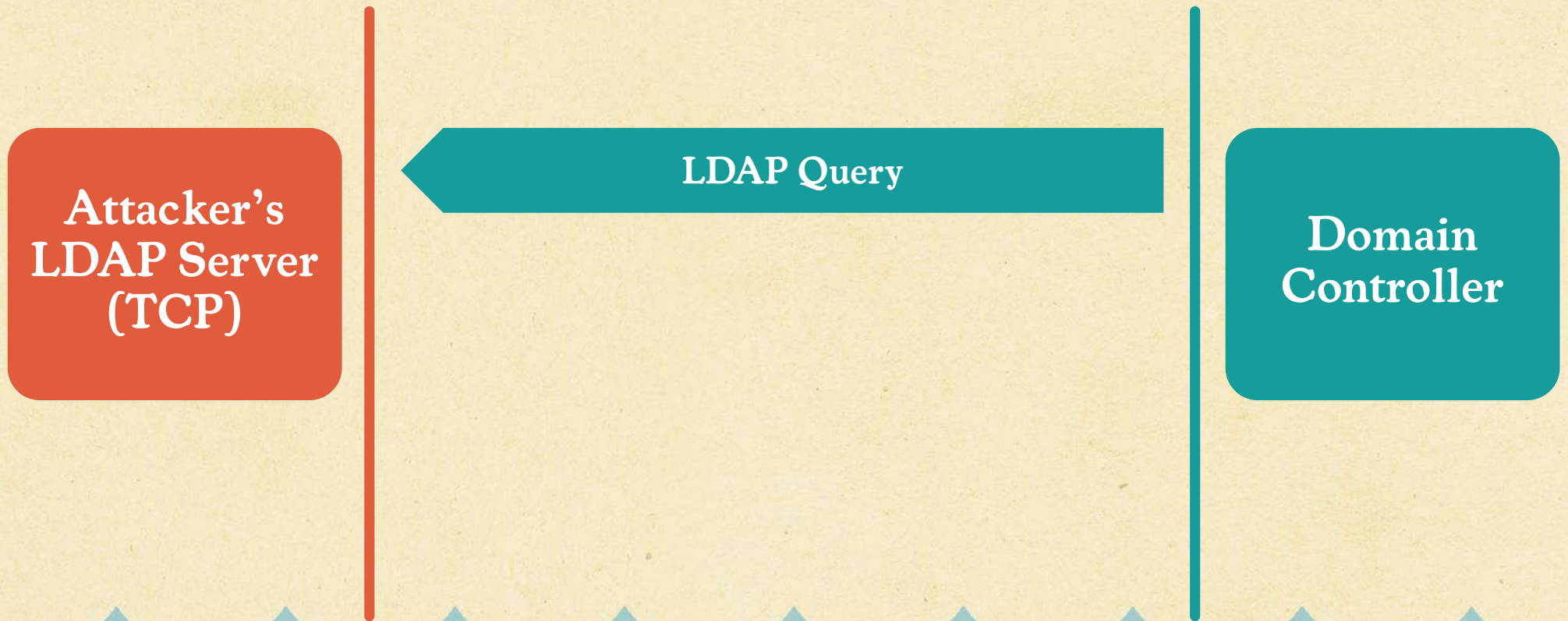
Win-DDoS



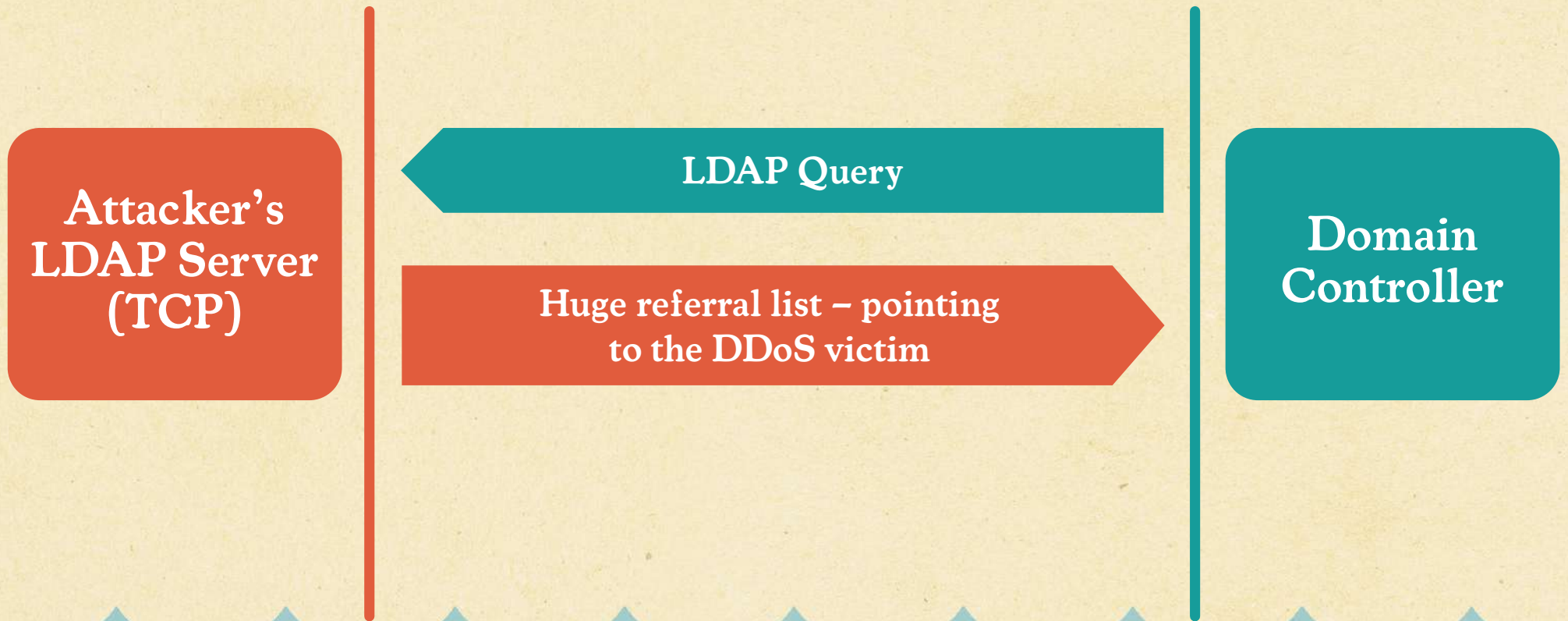
Win-DDoS



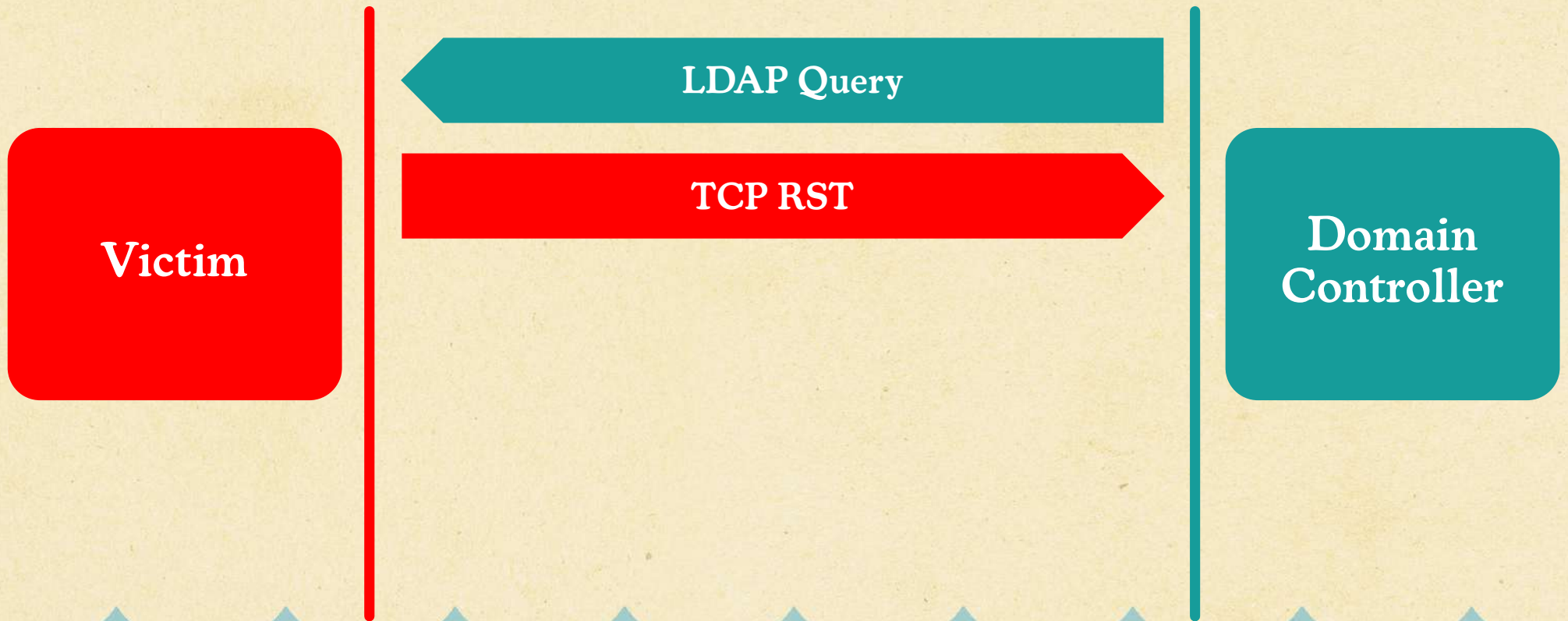
Win-DDoS



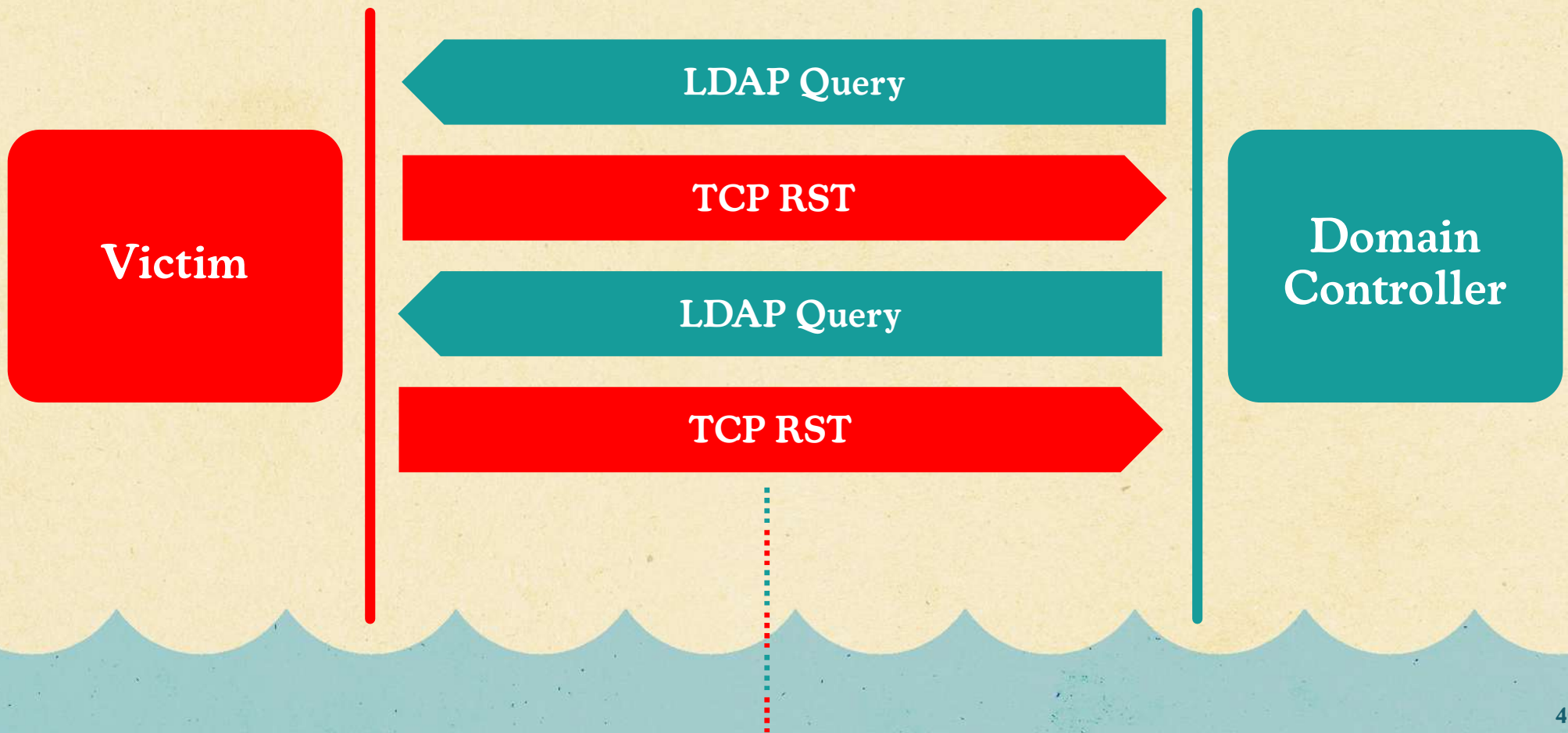
Win-DDoS



Win-DDoS



Win-DDoS



SM1

הוספת שקף סיכום או לשים באותו אחד ולהתמקד

Shahak Morag, 2025-07-03T09:51:02.422

Win-DDoS DEMO

The screenshot displays a network simulation environment for a Win-DDoS attack. It features four main components:

- Attacker:** A terminal window showing the execution of a Python script: `c:\temp\python main.py -d cnc-dos.xyz --dos-soldiers 192.168.1.90 192.168.1.88 192.168.1.91 --req-count 1000`.
- Victim Server:** A Windows PowerShell window showing the message: "Server is listening on 0.0.0.0 : 80".
- Domain Controller #1, #2, and #3:** Three Windows Server virtual machines, each running Wireshark to capture traffic on Ethernet 2. All three are configured with the filter `ip.addr == 192.168.1.87 and tcp.port == 80`.

The bottom of the image shows the taskbars of the three Domain Controller VMs, indicating they are running at 8:11 AM on 2/18/2025.

Win-DDoS - THE IDEAL DDoS



High bandwidth

Slide 48

SM1 Split this slide
Shahak Morag, 2025-06-24T11:33:36.956

SM2 להוסיף תמונה של קפיצה לגובה עם בר נמוך או בריצפה עם תמונה של סבתא מצליחה את זה.
Shahak Morag, 2025-07-03T09:53:02.528

SM3 להוסיף שקף הפרדה.
Shahak Morag, 2025-07-03T09:54:53.665

Win-DDoS - THE IDEAL DDoS



High bandwidth



No Cost

Slide 49

SM1 Split this slide
Shahak Morag, 2025-06-24T11:33:36.956

SM2 להוסיף תמונה של קפיצה לגובה עם בר נמוך או בריצפה עם תמונה של סבתא מצליחה את זה.
Shahak Morag, 2025-07-03T09:53:02.528

SM3 להוסיף שקף הפרדה.
Shahak Morag, 2025-07-03T09:54:53.665

Win-DDoS - THE IDEAL DDoS



High bandwidth



No Cost



No Compromised Bots

Slide 50

SM1 Split this slide
Shahak Morag, 2025-06-24T11:33:36.956

SM2 להוסיף תמונה של קפיצה לגובה עם בר נמוך או בריצפה עם תמונה של סבתא מצליחה את זה.
Shahak Morag, 2025-07-03T09:53:02.528

SM3 להוסיף שקף הפרדה.
Shahak Morag, 2025-07-03T09:54:53.665

Win-DDoS - LOWERING THE BAR



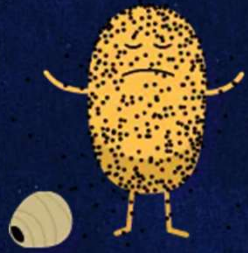
Slide 51

SM1 Split this slide
Shahak Morag, 2025-06-24T11:33:36.956

SM2 להוסיף תמונה של קפיצה לגובה עם בר נמוך או בריצפה עם תמונה של סבתא מצליחה את זה.
Shahak Morag, 2025-07-03T09:53:02.528

SM3 להוסיף שקף הפרדה.
Shahak Morag, 2025-07-03T09:54:53.665

WHAT WE ACHIEVED



Win-DDoS with LDAP

Where we are going: Win-DoS



**WHAT WILL HAPPEN
IF WE WILL USE TOO
MANY REFERRALS?**

TCP vs UDP



POTENTIAL REFERRAL OVERFLOW RAPID HUGE ALLOCATIONS

**If you were Microsoft how many
referrals would you allow?**

SM1 כמה הייתם נותנים 10,100 וככה הלאה microsoft לערב את הקהל אם הייתם
all you can it.
Shahak Morag, 2025-07-03T09:56:17.340

POTENTIAL REFERRAL OVERFLOW RAPID HUGE ALLOCATIONS

10?



If you were Microsoft how many referrals would you allow?

Slide 56

SM1 כמה הייתם נותנים 10, 100 וככה הלאה microsoft לערב את הקהל אם הייתם
all you can it.
Shahak Morag, 2025-07-03T09:56:17.340

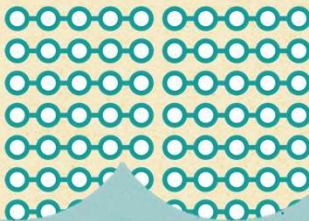
POTENTIAL REFERRAL OVERFLOW
RAPID HUGE ALLOCATIONS

10?



If you were Microsoft how many
referrals would you allow?

1,000?



Slide 57

SM1 כמה הייתם נותנים 10, 100 וככה הלאה microsoft לערב את הקהל אם הייתם
all you can it.
Shahak Morag, 2025-07-03T09:56:17.340

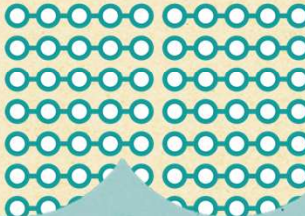
POTENTIAL REFERRAL OVERFLOW RAPID HUGE ALLOCATIONS

10?

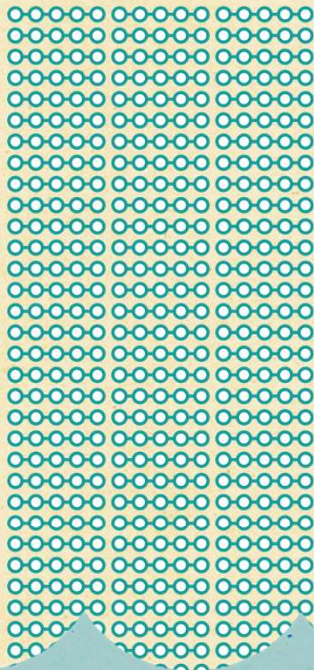


If you were Microsoft how many referrals would you allow?

1,000?



10,000?



Slide 58

SM1 כמה הייתם נותנים 10, 100 וככה הלאה microsoft לערב את הקהל אם הייתם
all you can it.
Shahak Morag, 2025-07-03T09:56:17.340

POTENTIAL REFERRAL OVERFLOW RAPID HUGE ALLOCATIONS

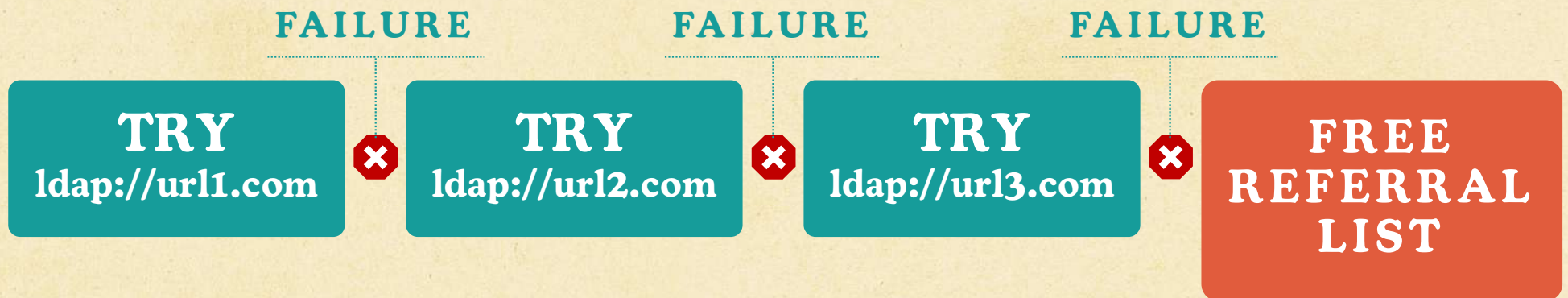
As far as we tested – no limit on
referral URL amount.
No size restrictions per URL.

ALL YOU CAN EAT!

Slide 59

SM1 כמה הייתם נותנים 10,100 וככה הלאה microsoft לערב את הקהל אם הייתם
all you can it.
Shahak Morag, 2025-07-03T09:56:17.340

REFERRAL OVERFLOW



List release happens only when
Domain Controllers hits the end



REFERRAL OVERFLOW

List release happens only
when Domain Controllers
hits the end

Growing Memory consumption → BSOD / Death of Lsass CVE-2025-32724

Your device ran into a problem and needs to restart. We're just collecting some error info, and then we'll restart for you.

50% complete



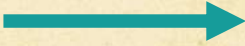
For more information about this issue and possible fixes, visit <https://www.windows.com/stopcode>

If you call a support person, give them this info:

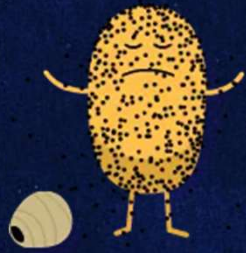
Stop code: CRITICAL_PROCESS_DIED



If we can create DoS with volume, we might do more...

Moving from LDAP to  RPC

WHAT WE ACHIEVED



Win-DDoS with LDAP



Win-DoS with LDAP



Where we are going: Win-DoS with RPC



HUNTING CRITERIA

WE SEARCHED FOR:

1. RPC over TCP/SMB.
2. Remote-Exposed RPC.
3. Unauthenticated/Low Privileged Access.



HUNTING CRITERIA

WE SELECTED ONES WITH:

1. Interfaces of critical processes.



HUNTING CRITERIA

WE SELECTED ONES WITH:

1. Interfaces of critical processes.
2. Large-numeric or big-length parameters.

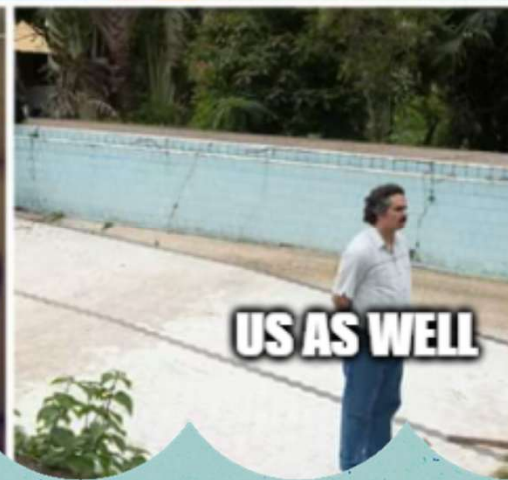




US WAITING FOR A DOS



ALSO US

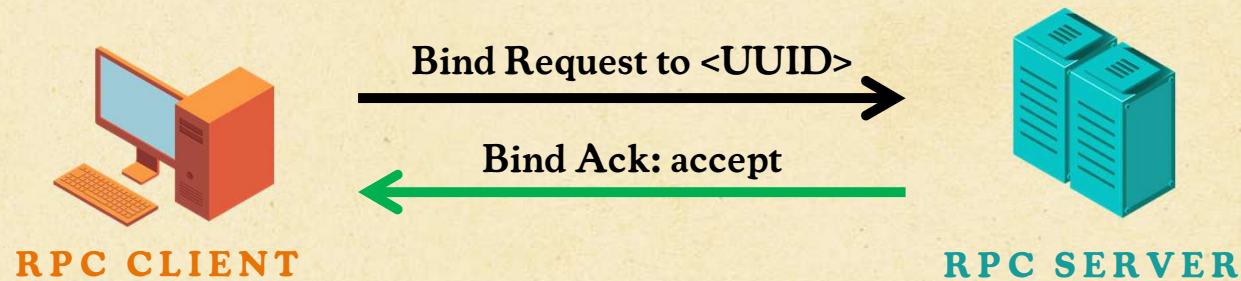


US AS WELL

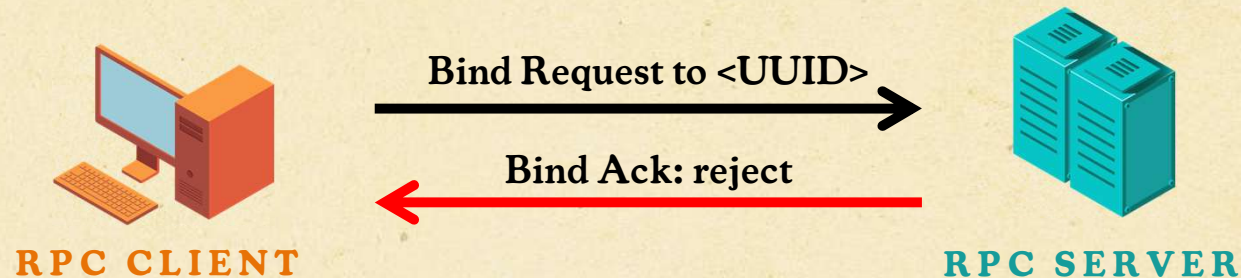
RPC BIND - THE HANDSHAKE OF RPC

Bind two options:

Accept:

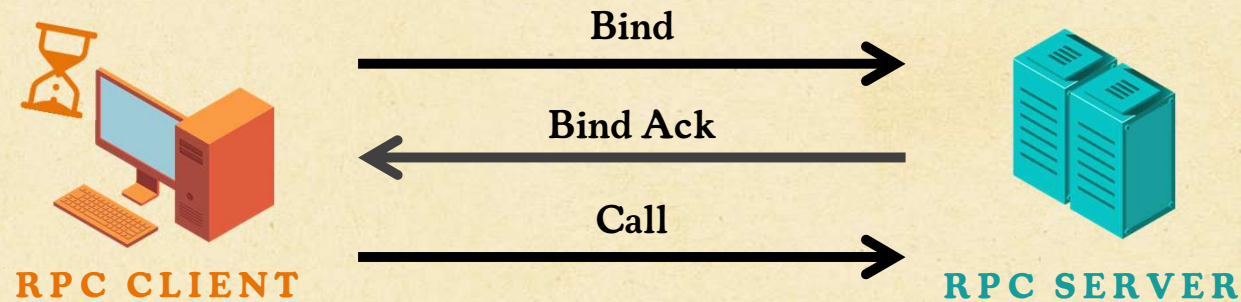


Reject:

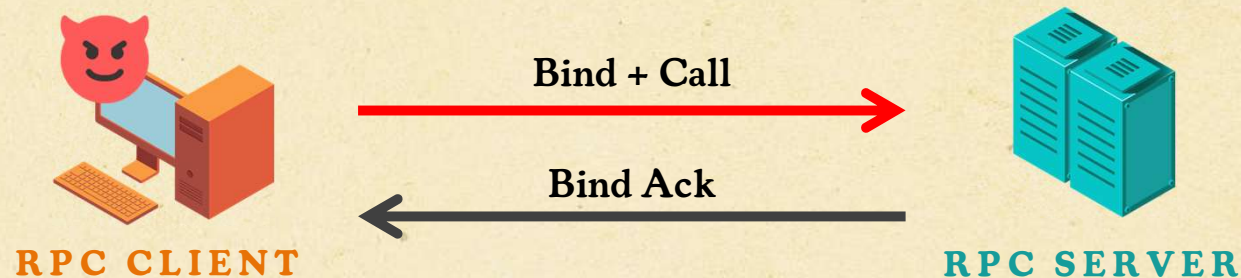


SKIP THE BIND ACK WAIT

Normal flow:



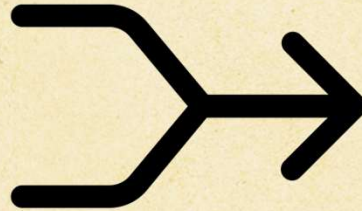
Optimized flow:



STATELESS RPC: ONE-PACKET, NO-WAIT



**Sending pre-built
packets**

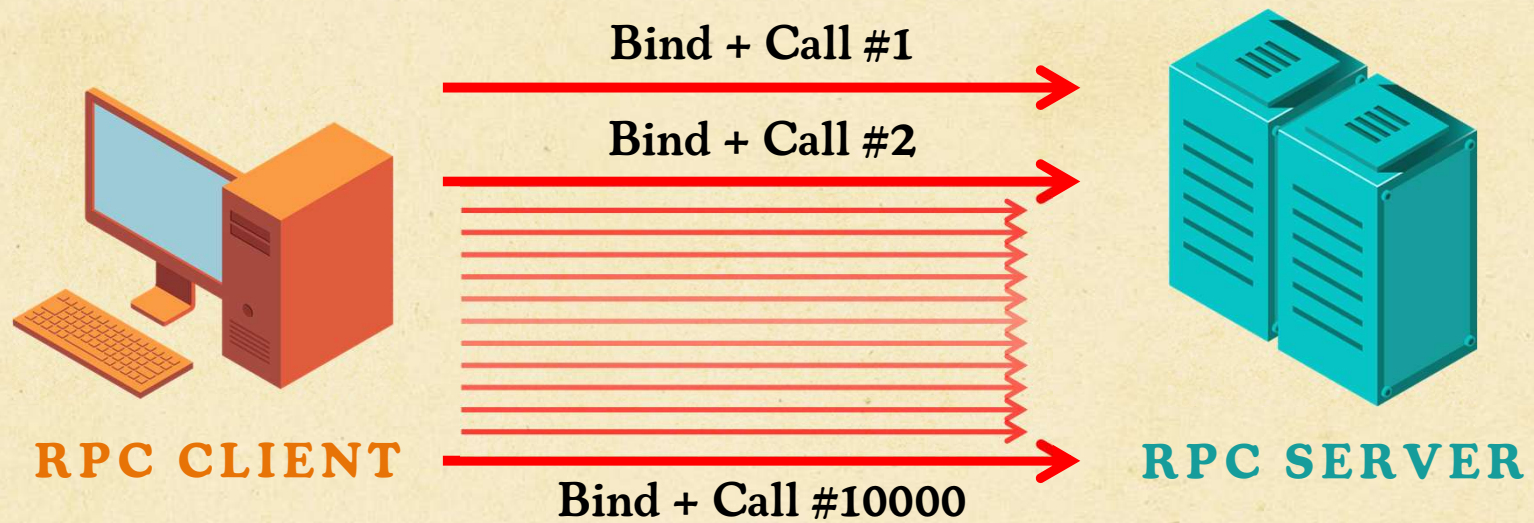


**Bind + RPC call in
a single packet**



**No wait for
Bind Ack**

STATELESS RPC IMPACT



CANDIDATE #1: DsrAddressToSiteNamesW

- ✓ Critical process (Lsass, NetLogon Interface).
- ✓ Available on DCs.
- ✓ Unauthenticated.
- ✓ Controllable size parameter: EntryCount.

*The maximum value for EntryCount is 32000.
The limit was chosen to prevent clients
from being able to force large memory
allocations on servers.*



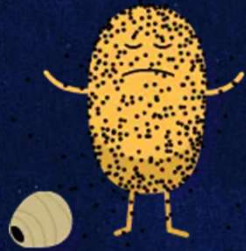
Microsoft

DsrAddressToSiteNamesW Bug CVE-2025-49716

$$\frac{8 \text{ bytes}}{\text{Socket Address Size}} \times \frac{32,000}{\text{Max Entry Count}} \times \frac{30,000}{\text{\# Stateless Calls}} \approx \frac{7.7\text{GB}}{\text{Exhausted Memory}}$$



WHAT WE ACHIEVED



Win-DDoS with LDAP



Win-DoS with LDAP



Win-DoS with RPC #1



Where we are going: More Win-DoS with RPC

We wanted even more!

**WHAT IF WE CAN
MAKE THE SAME
EFFECT AS DDOS?**

SM1

RPC CALL? בסוף הקוד של ה FREE למה הזיכרון עולה למרות שיש

חדשים מתועדפים על נוכחיים CALLS אולי בגלל ש

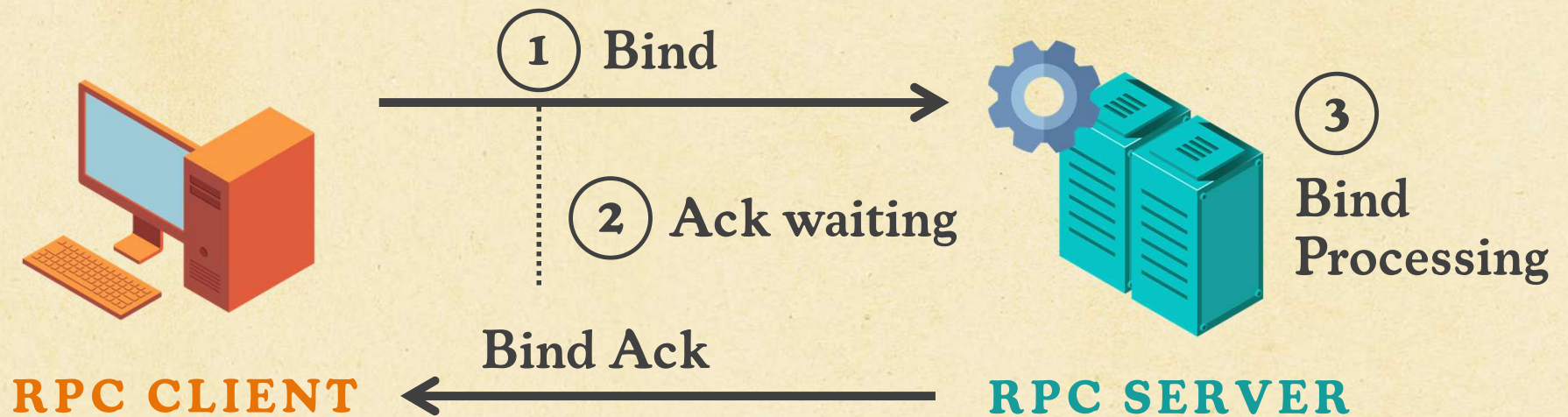
TORPEDOS? למה צריך את

חייבים להעלות את הזיכרון באופן מהיר כדי לגרום למערכת הפעלה לקרוס בכך שהיא לא תרשום את הדפים לדיסק. 1.
מספיק מהר.

לעשות סרטון שממחיש

Shahak Morag, 2025-06-23T14:19:09.357

IDENTIFYING THE ENTIRE BOTTLENECK IN RPC



GET RID OF THE BOTTLENECK

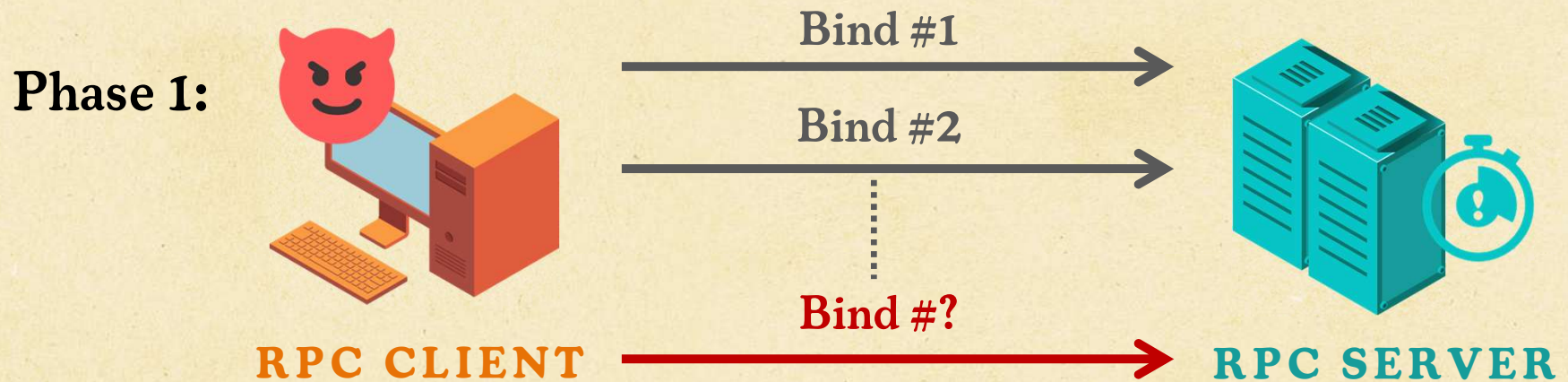
Phase 1:



Phase 2:

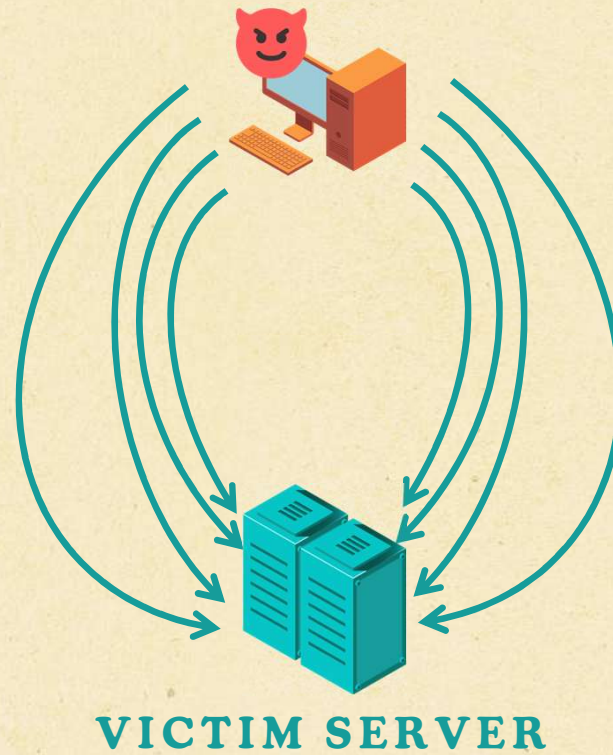


MAX BINDINGS BEFORE CONNECTION TIMEOUT



We tested **10 minutes** at least before timeout!

TorpeDoS - A Single-Computer DDoS





TorpeDoS – A SINGLE-COMPUTER DDoS

TorpeDoS - Pipes vs TCP Interfaces

SMB Pipes:



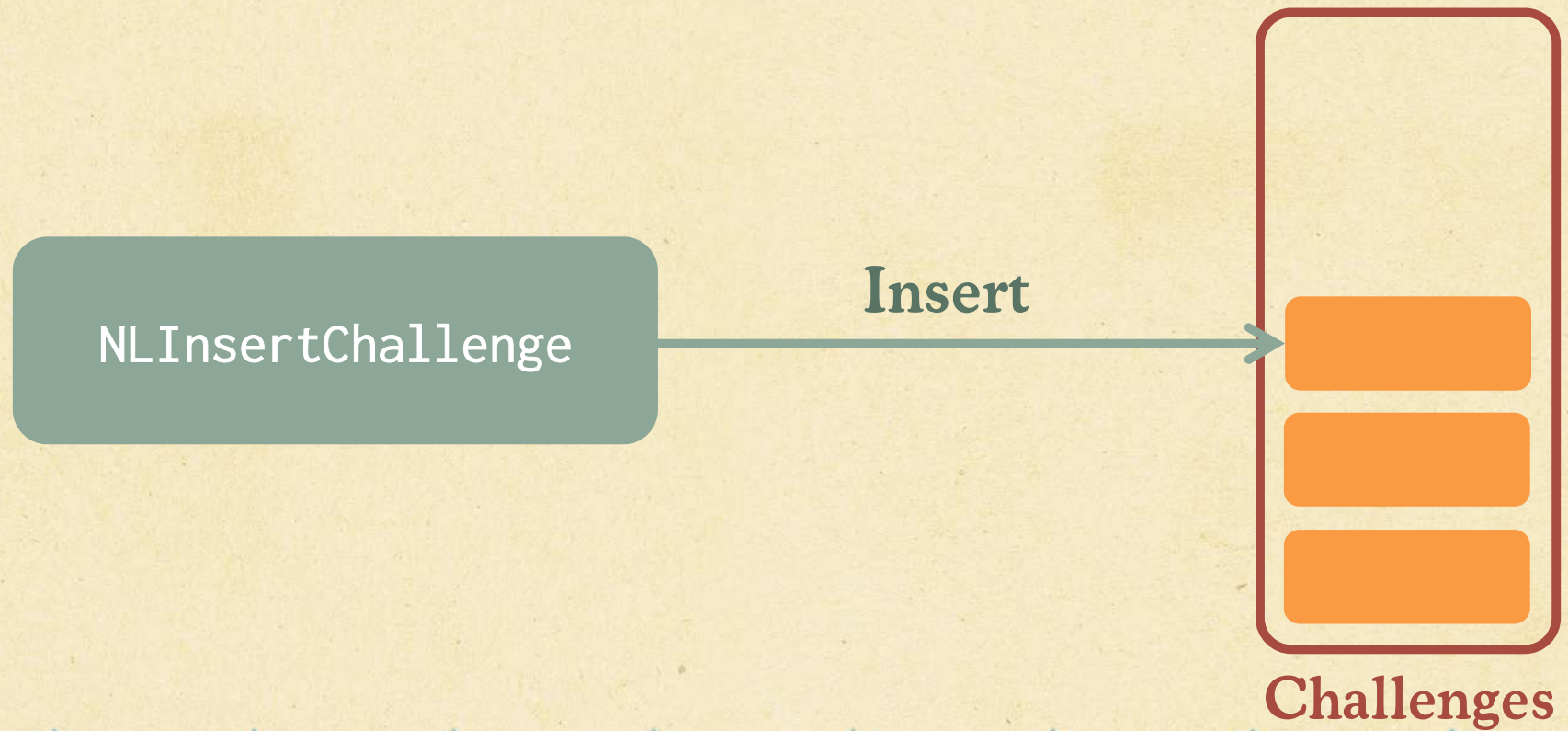
TCP:



CANDIDATE #2: NetrServerReqChallenge

- ✓ Belongs to critical process (Lsass, NetLogon Interface).
- ✓ Available on DCs.
- ✓ Unauthenticated.
- ✓ Controllable sized parameter: ComputerName.

NetrServerReqChallenge – Challenge Insertion



DoS enemy – NLScavangeOldChallenges



NetrServerReqChallenge Bug

CVE-2025-26673

Normal Flow:

You have 2 minutes, Go!

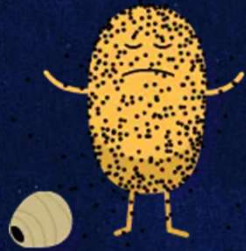


TorpeDoS Flow:

You have 2 minutes, Go!



WHAT WE ACHIEVED



✓ Win-DDoS with LDAP

✓ Win-DoS with LDAP



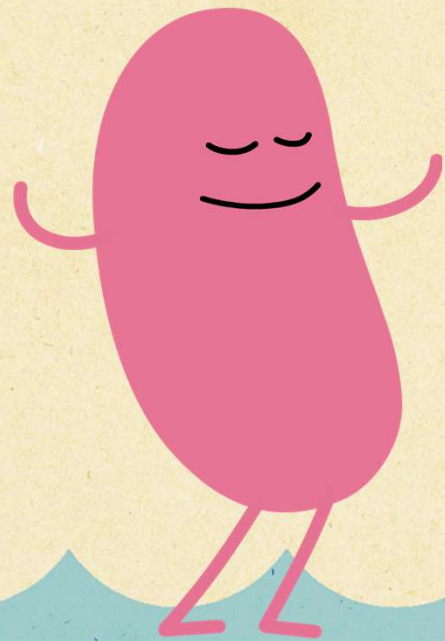
✓ Win-DoS with RPC #1

✓ Win-DoS with RPC #2



Where we are going: Windows 11 Win-DoS with RPC





We wanted to dream even

BIGGER!

WHAT IF WE COULD CRASH ANYTHING?



RPC INTERFACES IN WINDOWS ENDPOINT

**RPC interfaces
required authentication
on Windows 11**



SERVER & ENDPOINT CANDIDATE #1: NetrWkstaTransportEnum

- ✓ Belongs to critical process (`wkssvc.dll`).
- ✓ Available on all computers.
- Low privileged user call.
- ✓ Controllable sized parameter: `PreferredMaximumLength`.

SERVER & ENDPOINT CANDIDATE #1: NetrWkstaTransportEnum

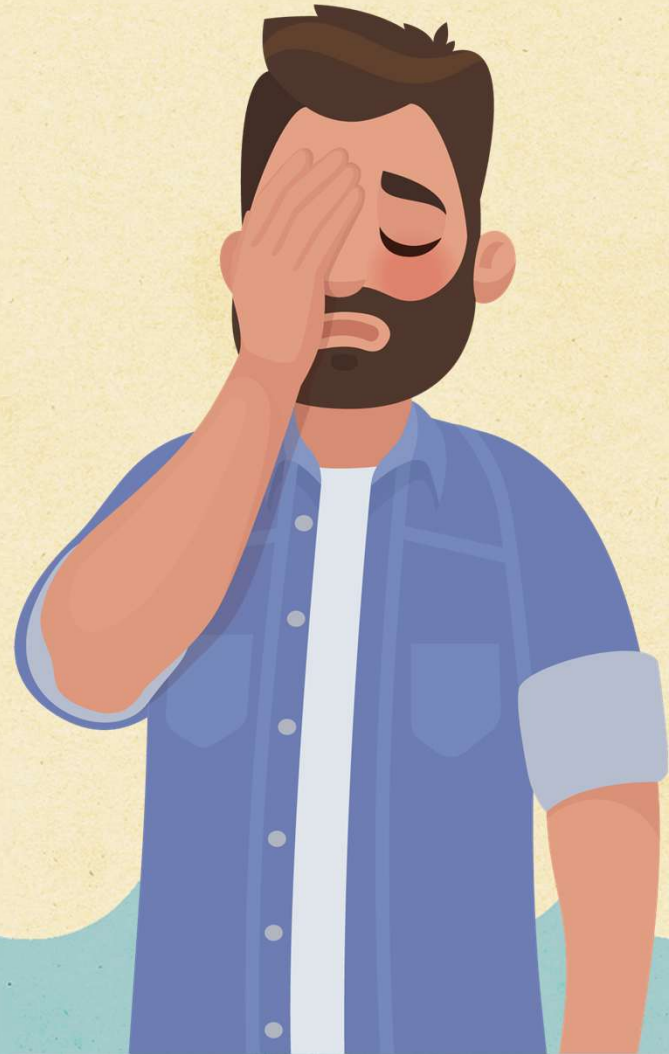
```
OutputBuffer = (PrefferedMaximumLength + 1) + 0xFFFFFFFFFE;  
result = LocalAlloc(LMEM_ZEROINIT, OutputBuffer);
```

GENERIC CANDIDATE #1: Failure Cause

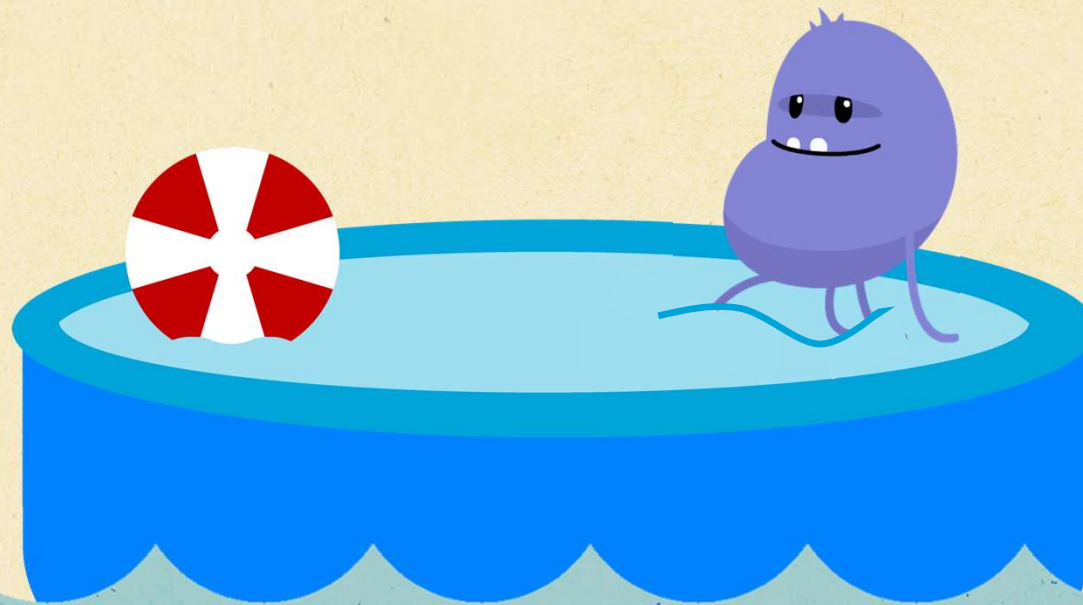
1. We called `LocalAlloc`.
2. Pages had `MEM_COMMIT` flag.
3. `MEM_COMMIT` make Windows allocate pages only on the **first accessed**.

**DEVELOPERS OVER
TRUST CLIENTS!**

**WHAT DO YOU
DO WHEN YOU
ARE STUCK?**



WE GO TO THE POOL!



SM1

RPC CALL? בסוף הקוד של ה FREE למה הזיכרון עולה למרות שיש

חדשים מתועדפים על נוכחיים CALLS אולי בגלל ש

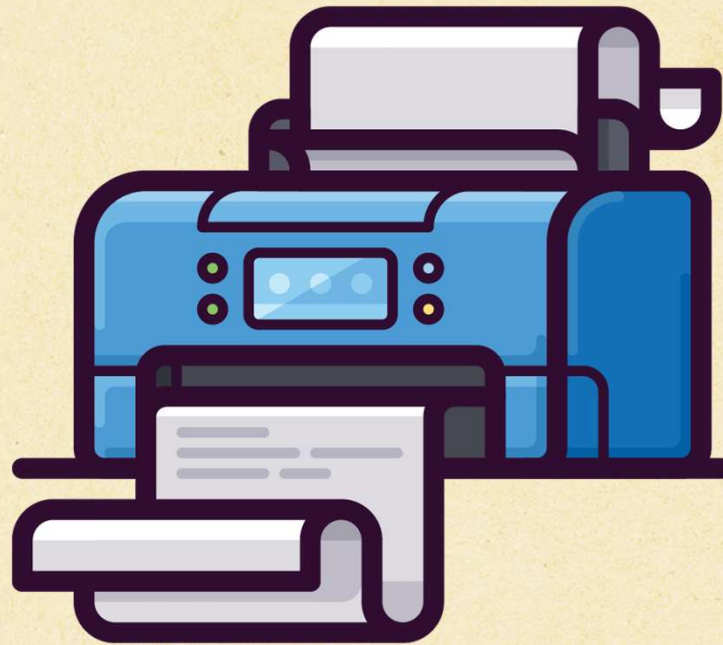
TORPEDOS? למה צריך את

חייבים להעלות את הזיכרון באופן מהיר כדי לגרום למערכת הפעלה לקרוס בכך שהיא לא תרשום את הדפים לדיסק. 1.
מספיק מהר.

לעשות סרטון שממחיש

Shahak Morag, 2025-06-23T14:19:09.357

Go to `spoolsv.exe`!



GENERIC CANDIDATE #2: RpcEnumPrinters

- ✓ Belongs to critical process (`spooler.exe`).
- ✓ Available on all computers.
- Low privileged user call.
- ✓ Controllable sized parameter: `Name`.

SM1 **spoolsv.**לרשום מה לעשות כשתקועים, ניגשים ל
Shahak Morag, 2025-07-03T10:13:32.706

AUTHENTICATED RPC PROBLEM

Unauthenticated RPC call:

Call packet

Authenticated RPC call:

Call packet



Previous Steps
based signing

AUTHENTICATED RPC PROBLEM

..... Unauthenticated RPC call packet

Call packet

Call packet



Signature
Based on
Previous Steps

..... Authenticated RPC call packet

AUTHENTICATED TorpeDoS



Spoolsv RPC DoS (CVE-2025-49722)

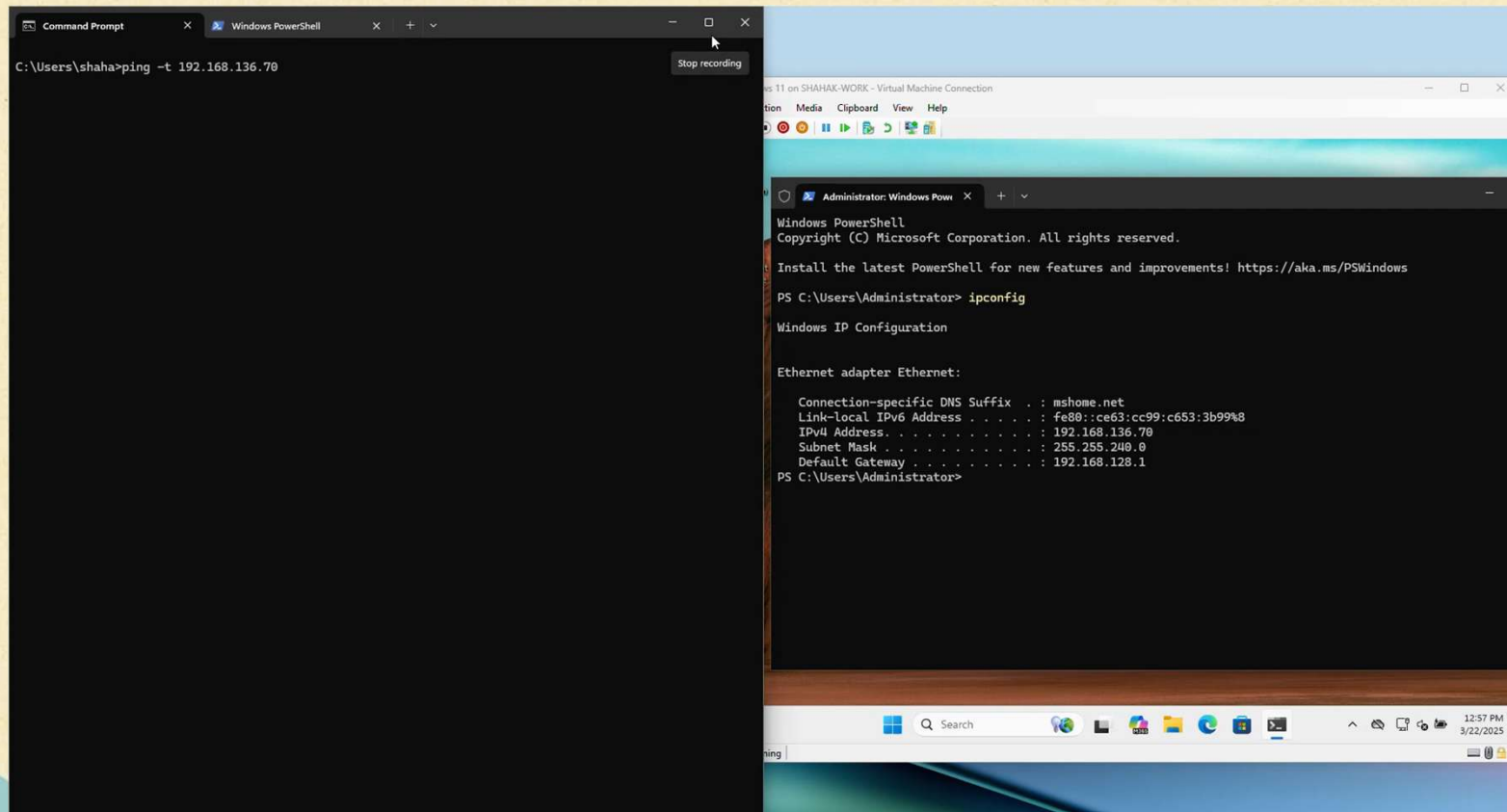
```
DWORD RpcEnumPrinters(  
    [in] DWORD Flags,  
    [in, string, unique] STRING_HANDLE Name,  
    [in] DWORD Level,  
    [in, out, unique, size_is(cbBuf), disable_consistency_check]  
        BYTE* pPrinterEnum,  
    [in] DWORD cbBuf,  
    [out] DWORD* pcbNeeded,  
    [out] DWORD* pcReturned  
);
```


**Finally, a single user
can crash all Windows
machines in a domain!**

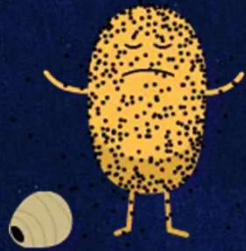


SM1 להוסיף mission accomplished
Shahak Morag, 2025-07-03T10:15:41.379

Win-DoS DEMO - CRASHING WINDOWS 11



WHAT WE ACHIEVED



✓ Win-DDoS with LDAP

✓ Win-DoS with LDAP



✓ Win-DoS with RPC #1

✓ Win-DoS with RPC #2



✓ Windows 11 Win-DoS with RPC

4 NEW DoS VULNERABILITIES DISCOVERY SUMMARY

Name	CVE	Developer Blind Spot	Bypass Concept	Privilege Required	Target
Referral Overflow	CVE-2025-32724	Remote triggered client	Not required	Anonymous	DC
NetLogon DoS #1	CVE-2025-26673	Transport-agnostic wrapped server	TorpeDoS	Anonymous	DC
NetLogon DoS #2	CVE-2025-49716	Transport-agnostic wrapped server	Stateless RPC	Anonymous	DC
SpoolSv DoS	CVE-2025-49722	Transport-agnostic wrapped server	TorpeDoS	Weak User	All Computers

SM1

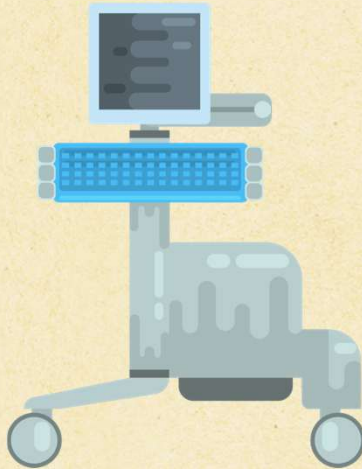
אולי טבלה או עיצוב אחר

Shahak Morag, 2025-07-03T10:16:26.131

DDoS and DoS ARE REAL WORLD RISKS



Money Loss



**Medical Equipment
Damage**



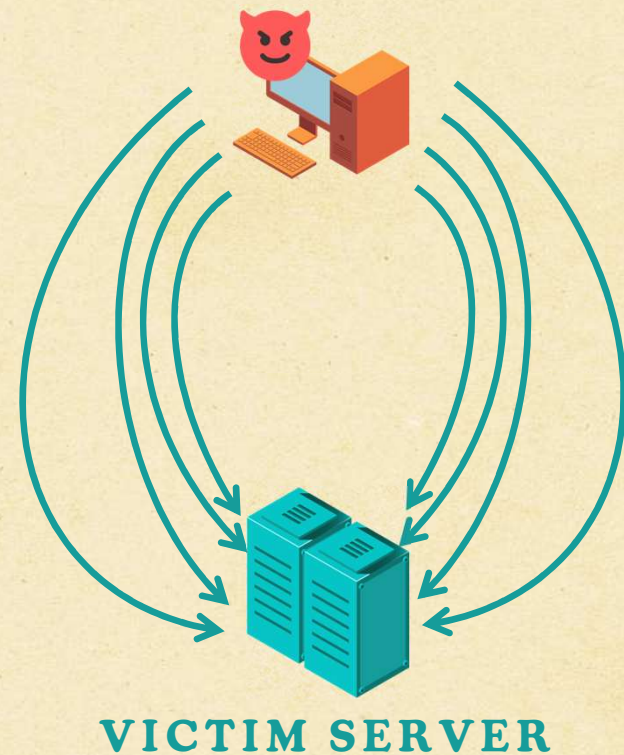
**Political
Incidents**

TAKEAWAYS

Any code that can be remotely triggered can be vulnerable to concurrency and resource abuse, even if it's intended to communicate with only a single entity

TAKEAWAYS

Organizations must assume that all their servers and endpoints can be targeted for DDoS attacks whether they are public facing or not.



TAKEAWAYS

Server to client transformation should be extremely carefully handled as it has multiple security risks



THE Win-DoS EPIDEMIC HAS BEGUN



GitHub + Q&A



@oryair1999



www.linkedin.com/in/or-yair/



@ShahakMo



www.linkedin.com/in/shahak-morag-6bb51b142/

<https://github.com/SafeBreach-Labs/Win-DoS>